

Web Research: the latest OWASP Mobile Top 10 for Mobile

Executive Summary

- The OWASP Mobile Top 10 2024 (Final Release) replaces the 2016 version and reflects modern mobile attack surfaces, including platform-specific misuses and credential mishandling.
- Key vulnerabilities include insecure data storage, weak authentication/authorization, misuse of platform features (Android Intents, iOS Keychain), and insecure communication.
- Real-world breaches (e.g., Strava API key leak, Uber driver app exposure) demonstrate that these risks lead to data exposure, brand damage, and regulatory penalties.
- The list is part of a broader OWASP Mobile Application Security (MAS) ecosystem that includes MASVS, MASTG, and MASWE – providing testing standards and controls.
- Practical mitigations like encryption (TLS 1.3, certificate pinning), secure local storage, and regular penetration testing remain essential.

Benefits / Opportunities

- Focused prioritisation – Developers and security teams can concentrate on the most prevalent risks rather than an endless list of possible threats (Indusface Blog, OWASP Developer Guide).
- Actionable checklists – Many sources provide pen-testing checklists aligned with the Mobile Top 10, enabling structured security assessments (Indusface Blog, GRSee).
- Alignment with mature standards – The Mobile Top 10 complements the OWASP Mobile Application Security Testing Guide (MASTG) and the Mobile Application Security Verification Standard (MASVS), creating a complete framework (Guardsquare, OWASP Developer Guide).
- Real-world relevance – The 2024 update adds risks like “Misuse of Platform Features” (e.g., unprotected Android Intents, iOS Keychain) that directly address recent high-profile incidents (The Ultimate Guide to OWASP Mobile Top 10 2024/2025 – Medium; OWASP Mobile Top 10 2024: A Security Guide).
- Multilingual and community-driven – The project is maintained by OWASP and ENISA, ensuring vendor-neutral, peer-reviewed guidance (OWASP Mobile Top 10 2024 Vulnerabilities – Indusface Blog).

Risks / Concerns

- Insecure Data Storage – Storing tokens, PII, or API keys in logs, world-readable files, or unencrypted databases remains a top risk. The Strava API key leak (2021) is a cited example (The Ultimate Guide... – Medium; OWASP Mobile Top 10 2024: A Security Guide).
- Weak Authentication / Authorization – Flawed session management and insufficient authorization checks can allow lateral movement and privilege escalation (OWASP Mobile Top 10 2024: A Security Guide; The OWASP Mobile Top 10: Key Risks and How to Mitigate Them – GRSee).
- Misuse of Platform Features – Improperly configured Android Intents or iOS Keychain usage can leak sensitive data. Uber's driver app exposed real-time location via intents (The Ultimate Guide... – Medium).
- Insecure Communication – Lack of TLS 1.3, missing certificate pinning, or mixed HTTP/HTTPS connections expose data in transit to interception (OWASP Mobile Top 10 2024: A Security Guide).
- Reverse Engineering & Dynamic Manipulation – Attackers use tools like Frida, JADX, and Ghidra to modify runtime behaviour, bypass SSL pinning, and extract secrets (The Ultimate Guide... – Medium; Revisiting the OWASP Mobile Top 10 – Guardsquare).
- Business Impact – A single vulnerability can lead to data breaches, severe brand trust erosion, regulatory fines (GDPR, CCPA), and loss of business continuity (The OWASP Mobile Top 10: Key Risks... – GRSee).

Practical Recommendations

1. Encrypt data at rest and in transit – Use strong encryption (e.g., AES-256 for local storage) and enforce TLS 1.3 with certificate pinning for all network communication (OWASP

Mobile Top 10 2024: A Security Guide).

2. Apply the principle of least privilege – Minimise permissions requested by the app and validate all intents/URL schemes; avoid storing sensitive data in logs or shared preferences (The Ultimate Guide... – Medium).
3. Implement robust authentication and session management – Use multi-factor authentication where possible, enforce short-lived tokens, and avoid hardcoded credentials (Indusface Blog; GRSee).
4. Conduct regular security testing – Combine static analysis (JADX, Hopper) with dynamic instrumentation (Frida) and automated tools (AppSweep) to uncover vulnerabilities early (Guardsquare; The Ultimate Guide... – Medium).
5. Leverage the OWASP MASVS/MASTG – Use the Mobile Application Security Verification Standard to define security requirements and the Testing Guide for comprehensive test cases (Revisiting the OWASP Mobile Top 10 – Guardsquare).
6. Stay updated – Monitor the official OWASP Mobile Top 10 page and OWASP events for future releases; the risk landscape evolves quickly (Top 10 Mobile Risks – OWASP Mobile Top 10 2024 Final Release).

Limitations

- Source quality varies – Most available information comes from third-party blog summaries (Indusface, Astra, Medium, GRSee, Guardsquare) rather than the official OWASP project page. The official 2024 Final Release page (owasp.org) mainly shows a comparison table and placeholder text – detailed risk descriptions were not provided in the snippets.
- No full official risk list in the sources – While sources 1 and 8 refer to a final list, the exact ten risks are not explicitly enumerated in the provided content. The snippets mention “Misuse of Platform Features”, “Insecure Data Storage”, “Weak Authentication/Authorization”, and “Insecure Communication” but do not confirm the complete set.
- Vendor bias possible – Sources from security vendors (Indusface, Guardsquare, 42Gears) may emphasise product-specific solutions. OWASP itself is vendor-neutral, but the cited articles may not reflect that neutrality.
- Limited depth on each risk – Most articles give high-level overviews; for detailed attack scenarios and mitigations, the OWASP Mobile Security Testing Guide (MASTG) should be consulted directly.
- One source focuses on web (42Gears) – It discusses the 2025 web application OWASP Top 10, which is only marginally relevant to mobile security.

Sources

1. OWASP Mobile Top 10 2024 Vulnerabilities | Indusface Blog — <https://www.indusface.com/learning/owasp-mobile-top-10/>
2. OWASP Mobile Top 10 2024: A Security Guide — <https://www.getastra.com/blog/mobile/owasp-mobile-top-10-2024-a-security-guide/>
3. Breaking Down OWASP Top 10 for Web Apps, Mobile, API, K8s and ... — <https://www.oligo.security/academy/breaking-down-owasp-top-10-for-web-apps-mobile-api-k8s-and-lms>
4. The Ultimate Guide to OWASP Mobile Top 10 2024/2025 - Medium — <https://medium.com/@izaz.haque246/the-ultimate-guide-to-owasp-mobile-top-10-2024-2025-d488c070d512>
5. Mobile Top 10 - OWASP Developer Guide — <https://devguide.owasp.org/en/07-training-education/06-mobile-top-ten/>
6. Revisiting the OWASP Mobile Top 10 | Guardsquare — <https://www.guardsquare.com/blog/revisiting-owasp-mobile-top-10>
7. The OWASP Mobile Top 10: Key Risks and How to Mitigate Them — <https://grsee.com/resources/pentesting/the-owasp-mobile-top-10-key-risks-and-how-to-mitigate-them/>

8. Top 10 Mobile Risks - OWASP Mobile Top 10 2024 - Final Release —

<https://owasp.org/www-project-mobile-top-10/2023-risks/>

9. OWASP Top 10: 2025 Release Candidate— What's New and Why These Risks Matter for Every Enterprise | 42Gears Mobility Systems — <https://www.42gears.com/blog/owasp-top-10/>

10. (■)■Report Review■2024 OWASP Mobile Top 10 Risks - Medium —

<https://medium.com/@security.tecno/%E2%85%B1-report-review-2024-owasp-mobile-top-10-risks-216b6cf6b2e3>